

A The User manual for the Server scanner

The Server scanner is the console application, that is distributed as the single executable file named `SCANNER.JAR`.

A.1 The application requirements

The Server scanner has following requirements:

- The Java Runtime Environment 1.8.
- The Linux operating system.
- Installed and properly configured application O-Saft 16.09.16 by the OWASP.
 - O-Saft 16.09.16 can be downloaded from <https://github.com/OWASP/O-Saft/releases/tag/16.09.16>.
 - If you require support for the old protocols and the obsolete cipher suites, you must follow the installation instructions described on <https://www.owasp.org/index.php/O-Saft/Documentation#DEPENDENCIES>.

A.2 The first run

On the Linux operating system, the Client scanner can be launched via following command:

```
java -jar scanner.jar
```

When you run the Server scanner for the first time, it will immediately exit and create the two XML files (`CONFIGURATION.XML` and `TARGETS.XML`). You will find the mentioned files in the folder, where `SCANNER.JAR` is located.

A.3 The configuration

The configuration consists of the two XML files.

A.3.1 configuration.xml

In the file CONFIGURATION.XML, you must specify the following values:

- **debug** – Should the Server scanner print the debug messages or not?
- **oSaftFolderAbsolutePath** – The absolute path to the location, where O-Saft is installed.
- **unknownTestResultIsError** – When the test ends with the unknown result, is this the secure outcome?

A.3.2 targets.xml

In the file TARGETS.XML, you will find the two main setting's categories – profiles and targets.

The profile

Each profile defines rules, that will be used during scanning a target. In the configuration directives, you will often encounter the attribute *mode* with the three allowed values (*canBe*, *mustBe*, *mustNotBe*). With the mentioned attribute mode, you must specify, how the scan's result will be interpreted.

- **protocols** – For the each protocol (recognized as the value *SSLv2*, *SSLv3*, *TLS 1.0*, *TLS 1.1* or *TLS 1.2*) you must define, which the protocol is considered secure.
- **vulnerabilitiesFree** – Allows you to run the scans for the well-known SSL/TLS vulnerabilities.
- **certificateValid** – Will run the test against some attributes of the certificate. Here, you must specify, which the minimum key size (for the RSA and ECDSA) is acceptable. Further, you may check, if the certificate is valid against your custom certificate authority (you must specify its root certificate as the Java KeyStore file).
- **ciphers** – You *may* state the cipher suites, that must or must not be supported by the remote server. Name of each cipher suite must be in the same format, that uses O-Saft.

The target

The target is the remote machine, that will be scanned according to the rules of the specified profile. Each target consists from the following attributes:

- **destination** – The IP address, domain or hostname of the machine, that will be tested. The value must be in the same format, that uses O-Saft.
- **profile** – The name of the profile, that will be used during scanning.
- **name** – The name of the target, just for your orientation. Such the name will be contained in the final report.

A.4 Running the application

When the both mentioned XML files contain the required values, the Server scanner is simple to use. Just run the application. It will automatically parse both XML files and performs the specified scans. When the scanning is completed, the Server scanner will create the report of results and exit.

A.5 The Report of results

After finishing all the scans, a new HTML file is created in the same directory, where SCANNER.JAR is contained. Such the file contains details about the performed tests. Please, be aware, that the report in the detail primary talks about the discovered vulnerabilities. The secure results are described briefly or not mentioned at all. If the report contains text in the brackets, it is output directly from O-Saft. Such the message could help you to determine a cause of the discovered problem.